

INGETIS

Ecole d'ingénierie informatique — 62 bis rue Gay-Lussac, 75005 Paris
EASRSI - RNCP38823

DOSSIER PROFESSIONNEL

Soutenance de certification RNCP Niveau 7

BLOC 2 — DÉPLOIEMENT ET MAINTENANCE DE L'INFRASTRUCTURE ECOTRACK

Spécialité : M1 Cybersécurité et Réseaux

Candidat(e) : SIDIBE SALIH

Numéro apprenant : 07 45 35 00 06

Année : 2025-2026

Date de soutenance : 30 / 06 / 2026

*Soutenance : 20 min de présentation + 20 min d'entretien avec le jury
Document confidentiel — INGETIS 2025-2026 — Usage académique strictement réservé*

Table des matières

Introduction. Présentation du Bloc 2	4
Problématique et Choix Techniques	4
Organisation et Numérique Responsable.....	5
2. Contexte et périmètre de la mission de sécurité	5
2.1 Présentation de l'organisation et du système d'information.....	5
.....	8
2.2 Cadre réglementaire et normatif applicable.....	8
Cadre Réglementaire.....	8
Normes et Référentiels Applicables	8
3. Modélisation des menaces	10
3.1 Méthodologie et périmètre d'analyse	10
3.2 Identification et évaluation des menaces	12
Analyse STRIDE — Étude des six menaces principales.....	13
3.3 Priorisation et plan de traitement des risques	15
Matrice d'Évaluation des Risques et Criticité.....	15
Plan de Traitement Prioritaire et Alignement Stratégique.....	17
4. Architecture de sécurité défensive.....	18
4.1 Conception de l'architecture en couches.....	18
Défense en profondeur — Architecture en 5 couches	18
4.2 Segmentation réseau et zones de confiance	20
Zones de sécurité et segmentation réseau	20
5. Solutions de protection déployées	22
5.1 Protection périmétrique et réseau	22
Pare-feu pfSense — Configuration et règles	22
Système de Détection et de Prévention d'Intrusions : IDS/IPS Suricata	23
Réseau Privé Virtuel : VPN OpenVPN — Accès Distants	24

Durcissement Système : OS Hardening du service SSH	24
5.2 Sécurisation des applications web (OWASP).....	25
Sécurisation du Top 10 OWASP via Nginx et ModSecurity.....	25
5.3 Chiffrement et infrastructure à clé publique (PKI).....	28
Stratégie de chiffrement.....	28
Infrastructure à clé publique (PKI)	30
6. Scripts d'automatisation sécurité.....	31
7. Conclusion et bilan	32
Posture de sécurité atteinte	32
Limites de l'architecture proposée	34
Vecteurs d'attaque résiduels.....	34
Perspectives d'évolution vers la certification ISO/IEC 27001.....	35
BIBLIOGRAPHIE ET SOURCES	36
1. Références Académiques et Normalisation (Gouvernance & Risques)	36
2. Documentations Techniques Officielles (Infrastructure & Durcissement)	36
3. Sources de Veille Technologique (Anglais Technique)	37
4. Références Numérique Responsable	37
Bilan personnel : Retour d'expérience sur le projet ECOTRACK....	Erreur ! Signet non défini.

Compétences transversales — Ces deux compétences doivent être démontrées dans chaque bloc et à chaque soutenance.

(1) *Maîtrise de l'anglais technique : veille technologique à partir de sources anglophones, références anglophones intégrées au dossier, capacité d'échange en anglais si sollicité par le jury.*

(2) *Numérique responsable : intégration des principes d'éco-conception, analyse de l'impact environnemental des solutions proposées, conformité aux réglementations en vigueur.*

Introduction. Présentation du Bloc 2

Consigne : Cette introduction présente le contexte général du dossier, la problématique traitée et l'articulation des différentes parties. Elle doit être rédigée en prose académique (entre 300 et 500 mots).

Ce dossier documente la conception et le déploiement d'une architecture de sécurité défensive pour un système d'information simulé. Il retrace la méthodologie de modélisation des menaces, la conception de l'architecture de sécurité en profondeur, le déploiement des solutions de protection, la mise en œuvre des mécanismes de chiffrement et la sécurisation des applications web selon le référentiel OWASP.

Rédigez ici votre introduction : contexte professionnel, enjeux du projet, problématique centrale et plan du dossier (300 à 500 mots)

Le présent dossier professionnel documente la conception, le déploiement opérationnel et la sécurisation d'une infrastructure informatique de production complexe. Réalisé dans le cadre du projet Ecotrack — une plateforme résiliente et hautement sécurisée, ce travail a été mené en équipe de cinq ingénieurs en cybersécurité : Abdallah, Boubacar, Wilfried, Terry et Salih. Afin de répondre aux exigences techniques et économiques du cahier des charges, l'intégralité de l'architecture a été virtualisée sur un serveur physique dédié hébergé chez Hetzner. L'ossature repose sur un système Debian équipé de l'hyperviseur Proxmox VE, permettant de simuler un environnement d'entreprise réaliste et isolé.

Problématique et Choix Techniques

La problématique centrale de notre démarche consiste à concevoir et déployer une architecture de sécurité défensive, holistique et en profondeur. Ce système doit être capable de sanctuariser un système d'information hétérogène — incluant des services web, des bases de données, des script IoT et des interfaces d'administration — tout en garantissant la disponibilité, l'intégrité et la confidentialité des données face à des menaces sophistiquées.

Pour y répondre, notre approche applique les principes du moindre privilège à travers six piliers stratégiques :

- **Segmentation Réseau** : Isolation stricte des flux via un pare-feu virtuel pfSense et des ponts virtuels dédiés (vmb0 à vmb5).
- **Haute Disponibilité en DMZ** : Rupture protocolaire par un cluster de reverse proxies HAProxy redondés via Keepalived, serveurs Nginx durcis par le WAF ModSecurity, et contrôle des flux sortants par un proxy Squid.
- **Résilience des Données** : Déploiement d'un cluster PostgreSQL hautement disponible orchestré par Patroni et etcd, épaulé par un cache Redis.
- **Supervision et SOC** : Centralisation des événements par le SIEM Wazuh (Elasticsearch), détection d'intrusions par l'IDS/IPS Suricata, et télémétrie de performance via Prometheus et Grafana.
- **Accès Distants Sécurisés** : Flux d'administration chiffrés par OpenVPN, durcissement des accès SSH et bannissement automatique par Fail2ban après trois tentatives erronées.
- **Support IoT** : Ingestion sécurisée des flux des scripts sur un broker MQTT Mosquitto.

Organisation et Numérique Responsable

Le dossier se structure en sept chapitres : le contexte et le périmètre de la mission (chapitre 2), la modélisation des menaces selon la méthodologie STRIDE (chapitre 3), l'architecture de sécurité en profondeur (chapitre 4), le détail des solutions de protection (chapitre 5), les scripts d'automatisation sécurité développés (chapitre 6), et le bilan de la mission (chapitre 7).

Sur le plan du numérique responsable, la mutualisation de l'infrastructure sur un unique serveur physique sous Proxmox minimise l'empreinte carbone et la consommation électrique. De plus, l'utilisation exclusive de logiciels libres et open-source élimine les coûts de licence, garantissant la transparence du code, la souveraineté économique et la pérennité technologique du projet.

2. Contexte et périmètre de la mission de sécurité

Consigne : Présentez l'organisation cible et la mission de sécurité. Soyez précis quant au périmètre, au cadre réglementaire applicable et aux objectifs de sécurité poursuivis.

2.1 Présentation de l'organisation et du système d'information

Description de l'organisation cible (secteur, taille, criticité du SI), cartographie du SI existant (applications, réseaux, annuaire, cloud), niveaux de sensibilité des données traitées

Organisation Cible : La Startup Ecotrack

Le projet Ecotrack est une plateforme d'infrastructure et de suivi écologique connectée, développée par une équipe de cinq étudiants-ingénieurs dans le cadre d'un projet académique à visée professionnelle. Cette organisation fictive mais réaliste représente une startup du secteur *Genentech*. Sa mission opérationnelle consiste à collecter des données environnementales spécifiques (température, poids, état de la batterie IoT et quantité) via des scripts dédiés, à les traiter en temps réel, puis à les restituer de manière sécurisée via un tableau de bord web d'entreprise.

Cartographie du SI

- **Couche réseau :** L'architecture s'appuie sur un serveur dédié physique loué auprès de l'hébergeur allemand Hetzner, fonctionnant sous une distribution Debian 12 avec l'hyperviseur Proxmox VE. Le cœur du routage, du filtrage et de la sécurité périmétrique est géré par une appliance virtuelle pfSense, configurée avec 6 interfaces réseau et ponts virtuels distincts (`vmbx0` à `vmbx5`) pour cloisonner hermétiquement chaque environnement.
- **Zone DMZ (10.10.1.0/24) :** Ce segment isole les points d'entrée de l'infrastructure afin d'assurer la rupture protocolaire et la répartition de charge. Il comprend deux conteneurs proxy essentiels, ECO-PROXY et ECO-LB-02, configurés en haute disponibilité réseau, (Keepalived avec l'IP virtuelle de production `10.10.1.100`). Ce pôle intègre HAProxy pour la répartition des flux, le serveur web Nginx couplé au pare-feu applicatif (WAF) ModSecurity, le proxy de détection avant-courrier Squid (*forward proxy* pour filtrer et auditer les flux sortants), ainsi qu'un cluster de consensus distribué etcd.
- **Zone Applicative (10.10.2.0/24) :** Ce compartiment étanche héberge la logique métier et le stockage persistant, totalement isolé du réseau public. On y retrouve le serveur de base de données principal ECO-DB (PostgreSQL 15 orchestré par Patroni en mode leader), son serveur de réplication continue ECO-DB-02 (réplica asynchrone), une instance Redis dédiée à la gestion du cache et de la persistance des sessions utilisateurs, ainsi que le conteneur ECO-APP qui propulse le site web et les tableaux de bord de l'application.
- **Zone Management (10.10.3.0/24) :** Segment réseau isolé dédié à la gouvernance de la sécurité, à l'audit et à la métrologie de l'infrastructure. Il héberge le serveur central ECO-SEC (Wazuh SIEM agissant avec des agents de surveillance déployés sur l'intégralité des machines villes et conteneurs) ainsi que le serveur ECO-MON qui centralise le stack d'observabilité opérationnelle (Prometheus, Grafana et Elasticsearch).
- **Zone IoT (10.10.4.0/24) :** Espace réseau hermétique dédié au traitement des métriques en provenance du terrain. Il comprend un broker MQTT **Mosquitto** sécurisé, un script de simulation de capteurs chargé de modéliser les flux de données (température, poids, batterie, quantité) ainsi qu'un script

d'ingestion automatisé chargé d'insérer les mesures validées dans le cluster PostgreSQL.

- **Accès distant** : Les flux d'administration et de gestion de l'infrastructure sont interdits depuis le WAN public. Les accès s'effectuent exclusivement via un tunnel chiffré OpenVPN déployé sur une passerelle Debian dédiée. La sécurité repose sur une infrastructure à clés publiques (PKI) avec l'attribution de 5 certificats utilisateurs nominatifs et stricts : *Abdallah, Boubacar, Wilfried, Terry et Salih*.

Niveaux de sensibilité des données

Pour structurer efficacement notre politique de sécurité et de défense en profondeur, les informations traitées et stockées par la plateforme Ecotrack sont classifiées selon trois niveaux de sensibilité distincts :

- **Données critiques** : Ce niveau regroupe les identifiants d'accès, les secrets d'authentification, les tokens de session active, les clés privées (SSH/TLS) et les credentials d'accès aux bases de données. Ces informations font l'objet d'un chiffrement fort au repos et en transit, et leur accès est restreint aux machines d'administration de la zone Management.
- **Données sensibles** : Ce niveau englobe les mesures IoT brutes récoltées sur le terrain (température, poids, batterie, quantité) ainsi que les fichiers de logs applicatifs. L'intégrité absolue et la non-répudiation de ces composants sont surveillées et garanties en temps réel par les fonctionnalités de contrôle d'intégrité (FIM) du SIEM Wazuh.
- **Données publiques** : Ce niveau correspond aux indicateurs consolidés, aux métriques environnementales agrégées et aux tableaux de bord d'affichage public. Ces données sont configurées en lecture seule et protégées contre les dénis de service au niveau des reverse proxies de la DMZ.

Interfaces   			
 WAN	↑	10Gbase-T <full-duplex>	10.0.0.2
 DMZ	↑	10Gbase-T <full-duplex>	10.10.1.1
 APPLICATIF	↑	10Gbase-T <full-duplex>	10.10.2.1
 GESTION	↑	10Gbase-T <full-duplex>	10.10.3.1
 IOT	↑	10Gbase-T <full-duplex>	10.10.4.1

Figure 1

2.2 Cadre réglementaire et normatif applicable

Tout système d'information est soumis à un ensemble de textes réglementaires et de standards normatifs qui encadrent la protection des données et des infrastructures. L'identification précise de ce cadre est un préalable indispensable à toute démarche de sécurisation.

Identification des obligations réglementaires (RGPD, NIS2, sectorielles) et des normes applicables (ISO 27001, référentiel ANSSI, NIST CSF) — Obligations spécifiques au secteur d'activité de l'organisation cible

Cadre Réglementaire

Règlement Général sur la Protection des Données (RGPD)

Bien que les informations collectées par l'infrastructure soient majoritairement de nature environnementale, la plateforme manipule des données à caractère personnel à travers les comptes des utilisateurs, les journaux d'accès et les jetons de session active. Afin de garantir une conformité stricte avec le règlement européen, des mesures rigoureuses de chiffrement des flux, de pseudonymisation des identifiants et de contrôle d'accès basé sur les rôles (RBAC) ont été intégrées nativement. Cette démarche technique répond directement aux exigences de l'article 25, matérialisant le principe de sécurité dès la conception (*Privacy by Design*), ainsi qu'à l'article 32 relatif à la sécurité et à la résilience des traitements.

Directive NIS 2

En tant que fournisseur de services numériques et plateforme de gestion d'infrastructure connectée, le projet s'aligne sur les exigences de la directive européenne de sécurité des réseaux et de l'information. Cette réglementation impose des obligations accrues en matière de gouvernance des risques, de résilience opérationnelle et de notification proactive des incidents de sécurité. Le choix d'une architecture de défense en profondeur, couplé au déploiement d'une cellule de détection et de réponse centralisée combinant le SIEM Wazuh et l'IDS/IPS Suricata, permet de satisfaire à ces obligations de surveillance continue et de gestion des vulnérabilités de la chaîne d'approvisionnement.

Normes et Référentiels Applicables

Norme ISO/IEC 27001

L'architecture de la plateforme intègre les meilleures pratiques de management de la sécurité de l'information en structurant ses contre-mesures selon les domaines de contrôle de ce standard international. Les configurations logicielles et matérielles ciblent spécifiquement la sécurité et la classification des actifs informatiques, le contrôle strict des accès logiques aux ressources, la sécurité des opérations industrielles par la centralisation des événements, ainsi que le cloisonnement des communications réseau au sein de l'hyperviseur.

Guide d'Hygiène Informatique de l'ANSSI

Le déploiement de l'infrastructure s'appuie sur les recommandations de l'Agence nationale de la sécurité des systèmes d'information à travers l'application rigoureuse de ses règles fondamentales de cyberdéfense. Cet alignement se traduit concrètement par une segmentation réseau hermétique opérée par le pare-feu, un durcissement drastique des configurations des serveurs d'accès SSH, une politique stricte de gestion des secrets d'authentification et l'activation d'une journalisation système centralisée et non répudiable.

Référentiel NIST Cybersecurity Framework (CSF)

La stratégie de sécurité globale de la plateforme couvre l'intégralité du cycle de vie des incidents tel que défini par le framework américain. La phase d'identification s'appuie sur une cartographie exhaustive du système d'information. La protection est matérialisée par le filtrage réseau et le pare-feu applicatif. La détection est assurée en temps réel par la corrélation de logs et l'analyse de paquets. La réponse aux incidents est orchestrée par des mécanismes d'alertes automatisées, tandis que la fonction de récupération est garantie par la haute disponibilité et la tolérance aux pannes du cluster de données.

OWASP Top 10

La protection de la couche applicative face aux cybermenaces du web se concentre sur l'atténuation des risques les plus critiques répertoriés par l'organisme open-source. Les vulnérabilités majeures, telles que les injections SQL, les failles d'authentification ou les scripts intersites, sont neutralisées en amont au niveau de la zone de transit réseau. Cette sécurité applicative est durcie par l'intégration de règles de filtrage comportemental et de signatures de sécurité au sein du pare-feu applicatif.

Standard PCI-DSS

Bien que l'infrastructure ne traite pas de transactions bancaires directes, les exigences rigoureuses de ce standard de l'industrie des cartes de paiement ont été adoptées comme modèle de référence pour le durcissement du système. Ses principes fondamentaux guident la politique de ségrégation stricte des environnements, l'isolement complet de la zone contenant les données hautement

sensibles, ainsi que les mécanismes de coffre-fort numérique mis en œuvre pour la protection et la rotation des secrets d'administration.

3. Modélisation des menaces

Consigne : La modélisation des menaces est une étape fondamentale de la sécurité by design. Elle permet d'identifier systématiquement les vecteurs d'attaque potentiels avant leur exploitation. Utilisez la méthodologie STRIDE ou PASTA.

3.1 Méthodologie et périmètre d'analyse

Méthodologie choisie (STRIDE, PASTA, LINDDUN...) et justification, périmètre du thread model (quels composants, quels flux de données), hypothèses retenues sur les capacités des attaquants (modèle d'attaquant)

Choix de la Méthodologie

Nous avons retenu la méthodologie STRIDE (*Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege*), développée par Microsoft, pour sa granularité technique et sa parfaite adéquation avec les architectures réseau et applicatives complexes. Ce modèle permet d'analyser systématiquement toutes les catégories de cybermenaces pesant sur chaque composant du système d'information. Son application s'appuie structurellement sur l'examen des diagrammes de flux de données (DFD), permettant d'identifier les vulnérabilités aux frontières de confiance de l'infrastructure.

Périmètre du Threat Modeling

Le périmètre d'analyse englobe l'intégralité des composants de l'infrastructure Ecotrack délimitée par ses frontières de confiance :

- **Couche Périmétrique et Accès :** L'interface WAN (vmbro), le pare-feu central pfSense, ainsi que les tunnels d'accès distants OpenVPN et les connexions SSH durcies.
- **Zone DMZ :** Les conteneurs de reverse proxy, le répartiteur de charge HAProxy, les serveurs web Nginx adossés au WAF ModSecurity, le forward proxy Squid et le cluster etcd.
- **Zone Applicative :** Le serveur d'exploitation de l'application web ECO-APP, le système de cache en mémoire Redis et le cluster de bases de données relationnelles PostgreSQL (ECO-DB et ECO-DB-02).
- **Zone Management :** La cellule de supervision centralisée regroupant le SIEM Wazuh et le stack d'observabilité Prometheus/Grafana.

- **Zone IoT :** Le broker MQTT Mosquitto, les modules de simulation et les scripts d'ingestion.

Type	Description	Utilisation ...	Utilisation ...	Processeur...	Durée de fon...	Utilisation ...	Utilisation ...	Étiquettes
Lxc	101 (ECO-PROXY)	3,3 %	3,5 %	0,3% de 1 ...	6 jours 16:03...	0,0% de 12...	0,2 %	proxy
Lxc	102 (ECO-LB-02)	3,0 %	2,1 %	0,3% de 1 ...	5 jours 03:21...	0,0% de 12...	0,1 %	proxy
Lxc	103 (DB-ECO-02)	-	-	-	-	-	-	-
Lxc	107 (APP-ECO)	1,5 %	7,6 %	0,0% de 1 ...	1 jour 04:36:04	0,0% de 12...	0,1 %	-
Lxc	111 (DB-ECO)	2,8 %	3,1 %	0,0% de 1 ...	21:52:04	0,0% de 12...	0,0 %	-
qemu	100 (PiSense)	0,0 %	72,7 %	2,2% de 2 ...	7 jours 16:27...	0,4% de 12...	2,3 %	PiSense
qemu	105 (ECO-SEC)	-	-	-	-	-	-	-
qemu	106 (IOT-MQTT)	0,0 %	80,9 %	0,1% de 2 ...	2 jours 01:24...	0,0% de 12...	2,6 %	-
qemu	108 (ECO-MON)	0,0 %	88,3 %	2,0% de 4 ...	3 jours 22:42...	0,7% de 12...	11,3 %	-
sdn	localnetwork (Debian-1213-b...	-	-	-	-	-	-	-
stock...	local (Debian-1213-bookwor...	83,6 %	-	-	-	-	-	-

Figure 2

```

sql

CREATE TABLE capteurs (
  id SERIAL PRIMARY KEY,
  poubelle_id VARCHAR(20),
  secteur VARCHAR(50),
  remplissage INTEGER,
  temperature NUMERIC(5,2),
  poids NUMERIC(6,2),
  humidite NUMERIC(5,2),
  batterie INTEGER,
  date_mesure TIMESTAMP DEFAULT NOW()
);

```

Figure 3

Les flux de données nominaux modélisés au sein de cette étude se concentrent sur deux axes directeurs :

- **Le flux Web / Utilisateur** : Utilisateur distant vers Internet → HAProxy → Nginx / ModSecurity → CR-APP → PostgreSQL / Redis.
- **Le flux IoT / Terrain** : Script → Broker Mosquitto → Script d'ingestion automatique → Base de données PostgreSQL.

Modèle d'Attaquant et Profils de Menaces

Pour évaluer la pertinence de nos contre-mesures, nous avons défini un modèle d'attaquant hiérarchisé en trois profils distincts, reflétant les risques cyber actuels :

- **Attaquant externe opportuniste** : Ce profil correspond à un agent malveillant de premier niveau (*script kiddie*). Dépourvu de connaissances internes sur l'architecture Ecotrack, il s'appuie sur des scripts automatisés pour scanner le réseau Internet à la recherche de vulnérabilités publiques connues ou de configurations par défaut non durcies.
- **Attaquant externe avancé** : Cet acteur ciblé dispose de compétences techniques avérées et d'outils de reconnaissance avancés (tels que Nmap, Nikto ou SQLMap). Il cible spécifiquement la surface d'exposition de la DMZ et cherche à exploiter des failles applicatives complexes, notamment celles répertoriées dans le Top 10 de l'OWASP.
- **Attaquant interne ou compromission d'accès** : Ce profil prend en compte le risque d'un utilisateur légitime (ou d'un tiers ayant usurpé l'un des 5 certificats nominatifs d'administration) agissant depuis le réseau interne ou le tunnel VPN. Son objectif est d'opérer une élévation de privilèges horizontaux ou verticaux pour exfiltrer des données critiques ou saboter l'infrastructure.

Hypothèses d'exclusion : Conformément aux objectifs de ce projet, les menaces liées à des acteurs étatiques de type APT (*Advanced Persistent Threat*) ne sont pas intégrées au périmètre. De même, les menaces de compromission physique des infrastructures matérielles hébergées au sein du datacenter sécurisé de Hetzner sont explicitement exclues du scope d'analyse.

3.2 Identification et évaluation des menaces

Pour chaque catégorie de menace (Spoofing, Tampering, Répudiation, Information Disclosure, Denial of Service, Elévation of Privilege dans le cadre de STRIDE), les actifs exposés, les vecteurs d'exploitation potentiels et les contre-mesures adéquates doivent être systématiquement documentés.

Pour chaque menace identifiée : actif cible, vecteur d'attaque, score de risque (CVSS ou échelle interne), contre-mesure proposée. Présentez au minimum 6 menaces significatives. Reference vers le diagramme de flux de données en Annexe [X]

Analyse STRIDE — Étude des six menaces principales

Menace 1 — Spoofing d'identité (SSH / OpenVPN)

- **Actif ciblé** : Passerelle d'administration et serveurs de la structure Ecotrack sous Debian (accès SSH sur port personnalisé).
- **Vecteur d'attaque** : Tentative d'usurpation d'identité par des attaques de force brute automatisées sur les interfaces d'accès ou tentative d'exploitation d'une clé privée OpenVPN dérobée à l'un des membres.
- **Score de criticité** : CVSS 8.1 (Élevé)
- **Contre-mesures implémentées** : Modification du port SSH standard pour limiter la découverte opportuniste, interdiction stricte de l'authentification par mot de passe au profit d'une authentification par clés cryptographiques asymétriques uniquement, et déploiement de **Fail2ban** configuré à un maximum de 3 tentatives infructueuses avant bannissement IP automatique. Les accès distants globaux sont verrouillés par des certificats OpenVPN individuels, nominatifs et révocables pour chacun des cinq ingénieurs.

Menace 2 — Tampering des données IoT en transit

- **Actif ciblé** : Broker MQTT **Mosquitto** hébergé au sein de la zone IoT (10.10.4.0/24).
- **Vecteur d'attaque** : Interception, altération ou injection de faux messages télémétriques (température, poids, batterie, quantité) via une attaque de type *Man-in-the-Middle* (MitM) orchestrée sur les segments réseau virtuels commutés.
- **Score de criticité** : CVSS 6.5 (Moyen)
- **Contre-mesures implémentées** : Isolation et étanchéité de la zone IoT via le pont virtuel dédié `vmbx5`. Mise en place de règles de filtrage strictes sur le pare-feu **pfSense** interdisant toute communication directe non sollicitée entre les capteurs IoT et l'Internet public ou les autres zones du système d'information. L'accès aux files d'attente du broker est soumis à une authentification MQTT obligatoire par identifiants uniques.

Menace 3 — Répudiation des actions d'administration

- **Actif ciblé** : Interface de gestion de l'hyperviseur **Proxmox VE** et consoles d'administration système.
- **Vecteur d'attaque** : Exécution d'actions destructrices ou malveillantes (telles que la suppression accidentelle ou intentionnelle d'une machine virtuelle Ecotrack) par un opérateur, sans génération de traces auditable permettant d'identifier formellement l'auteur.
- **Score de criticité** : CVSS 5.3 (Moyen)

- **Contre-mesures implémentées** : Centralisation, externalisation et indexation systématique des journaux d'événements vers le SIEM **Wazuh**. Des agents légers de surveillance active sont déployés sur l'intégralité des machines virtuelles et des conteneurs du parc pour assurer la collecte continue des logs d'audit. Les événements de sécurité critiques et les anomalies déclenchent des alertes visuelles et des notifications en temps réel au sein de la pile **Elasticsearch** et des tableaux de bord **Grafana**.

Menace 4 — Information Disclosure via l'API Web (Injection SQL)

- **Actif ciblé** : API Ecotrack hébergée sur le conteneur **ECO-APP** au sein de la zone applicative (10.10.2.0/24) et connectée au cluster PostgreSQL.
- **Vecteur d'attaque** : Injection de requêtes SQL malveillantes à travers les paramètres d'entrée de l'API web afin de contourner l'authentification et d'exfiltrer des données confidentielles (comptes d'accès, jetons de session, configurations système).
- **Score de criticité** : **CVSS 9.8** (Critique)
- **Contre-mesures implémentées** : Déploiement en amont du pare-feu applicatif (WAF) **ModSecurity** configuré avec l'ensemble de règles OWASP (*Core Rule Set* - CRS) activement mis à jour pour bloquer les structures de requêtes malveillantes. L'accès à l'API est masqué derrière le reverse proxy **Nginx**, interdisant toute exposition directe. Au niveau du code de l'application, l'utilisation systématique de requêtes préparées et paramétrées neutralise nativement la possibilité d'interprétation de code SQL par la base de données.

Menace 5 — Denial of Service sur la couche DMZ

- **Actif ciblé** : Adresse IP virtuelle partagée (VIP) **Keepalived** 10.10.1.100, constituant le point d'entrée réseau unique de l'infrastructure.
- **Vecteur d'attaque** : Attaque par inondation de paquets (SYN Flood, HTTP Flood) initiée depuis l'extérieur afin de saturer la table des connexions et les ressources matérielles des proxies de tête **ECO-PROXY** et **ECO-LB-02**.
- **Score de criticité** : **CVSS 7.5** (Élevé)
- **Contre-mesures implémentées** : Activation du système de détection et de prévention d'intrusions (IDS/IPS) **Suricata** au niveau du pare-feu pfSense, configuré avec des signatures spécifiques de mitigation DoS et DDoS. Le répartiteur de charge **HAProxy** applique des limites strictes de connexions simultanées et de taux de requêtes (*rate-limiting*) par adresse IP source. Le démon **Keepalived** assure quant à lui la bascule automatique et transparente de la VIP en quelques millisecondes vers le nœud de secours en cas de défaillance matérielle ou logicielle du proxy principal.

Menace 6 — Élévation de privilèges via Patroni / etcd

- **Actif ciblé** : Cluster de consensus clé-valeur **etcd** hébergé sur les instances de la DMZ, configuré pour piloter l'élection du nœud maître PostgreSQL.

- **Vecteur d'attaque** : Accès réseau non autorisé aux ports de l'API etcd permettant à un attaquant d'injecter une fausse configuration de consensus, forçant ainsi une élection arbitraire pour promouvoir un nœud malveillant ou compromis comme leader PostgreSQL, ce qui lui octroierait des privilèges totaux en écriture sur la base de données.
- **Score de criticité** : CVSS 8.8 (Élevé)
- **Contre-mesures implémentées** : Isolation réseau stricte : le service etcd est configuré pour écouter exclusivement sur l'interface réseau interne privée. Les flux inter-zones sont filtrés par le pare-feu pfSense, qui n'autorise que les connexions strictement nécessaires de la DMZ vers la zone applicative. Enfin, les communications et les élections entre les nœuds **Patroni** et le cluster etcd sont sécurisées par une authentification TLS mutuelle (mTLS) bidirectionnelle avec vérification stricte des certificats clients.

3.3 Priorisation et plan de traitement des risques

Matrice risque / criticité, priorisation des traitements (accepter / réduire / transférer / éviter), plan d'action associé à chaque risque prioritaire

Matrice d'Évaluation des Risques et Criticité

Afin de hiérarchiser les efforts de sécurisation sur l'infrastructure **Ecotrack**, les six menaces principales issues du modèle STRIDE ont été évaluées selon deux axes : la **Probabilité (P)** d'occurrence et l'**Impact (I)** sur le système d'information. Chacun de ces critères est noté sur une échelle de 1 (Faible) à 5 (Critique).

Le produit de ces deux facteurs détermine le score de **Risque Brut**, classé en trois catégories : Risque Modéré, Risque Élevé et Risque Critique.

Menace Identifiée	Probabilité (P)	Impact (I)	Risque Brut (R)	Niveau de Criticité	Stratégie de Traitement
Menace 1 : Spoofing SSH / VPN	3	5	15	CRITIQUE	Réduire (Fail2ban, clés ed25519, port personnalisé, certificats OpenVPN)
Menace 2 : Tampering des données IoT	2	4	8	Modéré	Réduire (Segmentation VLAN <code>vmb5</code> , authentification et contrôle pfSense)
Menace 3 : Répudiation d'administration	2	3	6	Modéré	Réduire (Centralisation des logs, agents Wazuh SIEM, alertes Elasticsearch)
Menace 4 : Injection SQL (API Web)	4	5	20	CRITIQUE	Réduire (WAF ModSecurity, règles OWASP CRS, requêtes préparées)
Menace 5 : Déni de Service (DoS DMZ)	3	4	12	Élevé	Réduire (Suricata IDS/IPS, limites HAProxy, haute

					disponibilité Keepalived)
Menace 6 : Élévation de privilège etcd	2	5	10	Élevé	Réduire (Authentification mTLS, écoute locale, filtrage inter-zones pfSense)

Plan de Traitement Prioritaire et Alignement Stratégique

Conformément aux exigences de gouvernance de la sécurité, aucune menace n'a fait l'objet d'une acceptation de risque sans mesure de contournement, et aucun risque n'a été transféré (l'assurance cyber étant exclue de ce périmètre académique). Les stratégies se concentrent exclusivement sur la **réduction active du risque**.

Risques Critiques : Traitement Immédiat

Ces scénarios faisaient peser un risque d'interruption totale ou de compromission systémique majeure sur la plateforme Ecotrack, imposant l'application de contre-mesures immédiates lors du déploiement :

- **L'Injection SQL** : Traitée en priorité absolue. La protection est opérée en coupure par le pare-feu applicatif (WAF) ModSecurity adossé au jeu de règles OWASP CRS au niveau de la DMZ. En profondeur, la vulnérabilité est éliminée à la source dans le code applicatif par l'utilisation systématique de requêtes préparées.
- **Le Spoofing SSH / VPN** : Résolu par un durcissement complet des protocoles d'accès. L'accès à l'infrastructure s'appuie sur une infrastructure à clés publiques (PKI) OpenVPN délivrant 5 certificats nominatifs stricts, combinée au blocage des forces brutes par Fail2ban et à l'interdiction des mots de passe pour les sessions SSH.

Risques Élevés : Traitement Appliqué

Ces menaces ciblent la stabilité opérationnelle et les mécanismes de gouvernance interne du cluster :

- **Le Dénî de Service sur la DMZ** : Contenu par l'analyse comportementale de l'IDS/IPS Suricata positionné sur pfSense, qui applique des règles de blocage dynamique. Le reverse proxy HAProxy absorbe les pics de charge via des directives de *rate-limiting*, tandis que Keepalived maintient la disponibilité de l'IP virtuelle en cas de défaillance d'un nœud.
- **L'Élévation de privilège via etcd** : Circonscrire en forçant le service etcd à écouter exclusivement sur le segment réseau interne de la DMZ. Les droits de modification des

configurations du cluster PostgreSQL par Patroni sont verrouillés par l'implémentation d'une authentification TLS mutuelle (mTLS) bidirectionnelle entre les nœuds.

Risques Modérés : Traitement et Surveillance Continue

Ces risques présentent une probabilité ou un impact plus faible, mais font l'objet d'un contrôle rigoureux pour éviter toute dérive de sécurité :

- **La Répudiation d'administration et le Tampering IoT :** Couverts de manière transverse par le compartimentage réseau hermétique de pfSense (notamment le pont `vmbx5` pour l'IoT) et par la surveillance continue du SIEM Wazuh. Les agents Wazuh agissent comme des sondes d'intégrité de fichiers (FIM) et de centralisation des logs, assurant la traçabilité complète de l'activité du système d'information.

4. Architecture de sécurité défensive

Consigne : Présentez l'architecture de sécurité en profondeur retenue. Le principe de défense en profondeur impose la superposition de couches de protection complémentaires. Joignez le schéma en Annexe.

4.1 Conception de l'architecture en couches

L'architecture de sécurité retenue s'appuie sur le principe de défense en profondeur, qui postule qu'aucune mesure de sécurité n'est infaillible et que la compromission d'une couche ne doit pas entraîner celle de l'ensemble du système.

Description de chaque couche de sécurité : périmétrique (DMZ, firewall NGFW), réseau (VLAN, segmentation, Zéro Trust), système (Harding, EDR), application (WAF, SAST), données (chiffrement, RBAC) — Reference vers schéma d'architecture en Annexe [X]

Défense en profondeur — Architecture en 5 couches

Notre architecture de sécurité s'articule autour de cinq couches superposées, conformément au principe de défense en profondeur (*Defense in Depth*). Cette configuration garantit qu'aucune défaillance ou compromission d'une couche unique ne peut entraîner la compromission de l'ensemble du système d'information.

Couche 1 — Périmétrie (DMZ + Firewall NGFW)

Le pare-feu **pfSense** constitue le point d'entrée unique et obligatoire de l'infrastructure Ecotrack. Déployé sur l'interface réseau `vmbr1` (adresse IP hôte `10.0.0.2`), il inspecte et filtre la totalité du trafic transitant entre Internet (`vmbr0/WAN`) et les zones de confiance internes.

La solution **Suricata** y est intégrée en mode IDS/IPS pour assurer la détection de signatures malveillantes et le blocage automatique des attaques réseau en temps réel. En amont des zones sensibles, la zone DMZ (`vmbr2`, réseau `10.10.1.0/24`) héberge exclusivement les composants exposés aux flux externes :

- **HAProxy** : Répartition de charge et terminaison des connexions entrantes.
- **Nginx + ModSecurity** : Pare-feu applicatif (WAF) dédié à la protection contre les exploits web.
- **Squid** : *Forward proxy* régulant et auditant les requêtes sortantes des machines de production vers Internet (mises à jour de paquets, flux API).
- **etcd** : Magasin de clés/valeurs distribué assurant la coordination sécurisée du cluster de données.

Couche 2 — Réseau (Segmentation et Modèle Zero Trust)

Le cloisonnement logique de l'infrastructure s'appuie sur la création de zones de sécurité distinctes et hermétiques, matérialisées par les ponts virtuels de l'hyperviseur Proxmox VE :

- **Segment WAN** : `vmbr0` (Interface physique connectée au réseau Hetzner).
- **Segment Access pfSense** : `vmbr1` (`10.0.0.0`).
- **Segment DMZ** : `vmbr2` (`10.10.1.0/24`).
- **Segment Applicatif** : `vmbr3` (`10.10.2.0/24`).
- **Segment Management / SOC** : `vmbr4` (`10.10.3.0/24`).
- **Segment IoT** : `vmbr5` (`10.10.5.0/24`).

Les règles de filtrage définies sur pfSense appliquent une philosophie stricte de *Zero Trust* : tout trafic inter-zones est soumis à une politique d'interdiction par défaut (*Default Deny*). Seuls les flux techniques légitimes et documentés dans la matrice des flux sont explicitement autorisés.

Couche 3 — Système (Hardening et Surveillance Active)

Chaque machine virtuelle et conteneur au sein du projet Ecotrack a fait l'objet d'un durcissement système (*OS Hardening*) rigoureux selon les guides de bonnes pratiques de l'ANSSI. Cette configuration inclut la désactivation systématique des services et protocoles inutiles, l'automatisation des mises à jour de paquets de sécurité, ainsi qu'un verrouillage drastique du service SSH (port par défaut modifié, interdiction du compte root, authentification exclusive par clés asymétriques).

La surveillance opérationnelle est déléguée aux agents **Wazuh** déployés sur l'ensemble du parc. Ils assurent en continu le contrôle d'intégrité des fichiers sensibles (FIM), la détection d'anomalies ou de rootkits, ainsi que l'envoi chiffré des journaux d'audit vers le serveur SIEM centralisé.

Couche 4 — Application (WAF et Sécurité OWASP)

Le serveur web Nginx couplé au module de pare-feu applicatif **ModSecurity** immunise la plateforme contre les risques majeurs du Top 10 de l'OWASP. Les ensembles de règles standardisées **OWASP Core Rule Set (CRS)** sont activés et finement configurés : d'abord en mode détection pour identifier les faux positifs, puis basculés en mode prévention active pour intercepter et bloquer instantanément les tentatives d'injections, de Cross-Site Scripting (XSS) et d'attaques applicatives.

Conformément à cette isolation multicouche, l'application Ecotrack s'exécute de manière confinée au sein de la zone applicative et ne dispose d'aucune exposition directe sur le réseau Internet public.

Couche 5 — Données (Chiffrement et Gestion RBAC)

La couche la plus profonde de notre modèle protège les actifs informationnels de la startup. Les données au repos au sein du cluster **PostgreSQL** font l'objet d'un chiffrement ciblé au niveau des colonnes contenant les informations critiques. L'intégralité des connexions de transit avec la base de données est soumise à l'utilisation obligatoire du protocole TLS.

En parallèle, le cache en mémoire **Redis** gère la persistance des jetons de session utilisateur en appliquant des durées de vie (*Time-To-Live* - TTL) restrictives pour limiter la fenêtre d'opportunité d'une éventuelle compromission. Enfin, le contrôle d'accès basé sur les rôles (**RBAC**) de PostgreSQL applique le principe du moindre privilège en attribuant des droits d'exécution minimalistes et limités aux stricts besoins des comptes applicatifs.

4.2 Segmentation réseau et zones de confiance

Architecture réseau : zones de sécurité définies, VLAN configurés, règles de filtrage interzones, implémentation du modèle Zéro Trust (si applicable)

Zones de sécurité et segmentation réseau

Le partitionnement logique de l'infrastructure **Ecotrack** repose sur une isolation stricte des privilèges réseau. L'hyperviseur Proxmox VE orchestre cette étanchéité au niveau de la couche de liaison par le biais de ponts virtuels dédiés (`vmbbr`), interdisant nativement la communication directe entre les différents tiers.

Cartographie des segments réseau

- **Zone WAN (vmb0) :** Interface réseau physique connectée directement aux infrastructures de l'hébergeur Hetzner. Entièrement exposée sur l'Internet public, sa surface d'exposition est intégralement verrouillée et contrôlée par l'interface externe de pfSense.
- **Zone Access pfSense (vmb1, réseau 10.0.0.0/24) :** Segment de transit technique assurant la liaison point à point entre le système hôte Debian et l'interface amont du pare-feu pfSense (configuré avec l'adresse IP fixe 10.0.0.2).
- **Zone DMZ (vmb2, réseau 10.10.1.0/24) :** Zone tampon hébergeant les points d'entrée applicatifs de l'infrastructure. Elle comprend les instances de reverse proxy et de répartition de charge **ECO-PROXY** (10.10.1.10) et **ECO-LB-02** (10.10.1.11), unifiées derrière l'adresse IP virtuelle partagée (VIP) de haute disponibilité **Keepalived** (10.10.1.100).
- **Zone Applicative (vmb3, réseau 10.10.2.0/24) :** Cœur logique du système, formellement isolé de l'Internet public. Ce segment héberge l'instance de traitement web **ECO-APP** (10.10.2.20), le nœud de persistance PostgreSQL maître **ECO-DB** (10.10.2.30), son réplica synchrone **ECO-DB-02** (10.10.2.31).
- **Zone Management (vmb4, réseau 10.10.3.0/24) :** Segment hautement restreint dédié à l'administration, à la sécurité et à l'observabilité. Il regroupe le serveur SIEM centralisé **ECO-SEC / Wazuh** (10.10.3.10) et la console de supervision **ECO-MON / Prometheus et Grafana** (10.10.3.11).
- **Zone IoT (vmb5, réseau 10.10.5.0/24) :** Compartiment étanche dédié aux flux de données du terrain. Il isole le broker MQTT Mosquitto et les modules d'ingestion de données (température, poids, batterie, quantité). Ce réseau ne dispose d'aucune route directe vers l'extérieur.

Règles de filtrage inter-zones sur pfSense

L'accès entre ces compartiments est gouverné par une matrice de flux stricte, configurée sur l'appliance pfSense selon le principe du moindre privilège :

- **Flux Internet à Zone DMZ :** Trafic exclusivement toléré sur les ports standardisés 80 (HTTP) et 443 (HTTPS). Les requêtes sont impérativement routées vers la VIP Keepalived 10.10.1.100. Tout autre protocole ou port à destination de cette zone est immédiatement rejeté.
- **Flux Zone DMZ à Zone Applicative :** Les connexions ne sont autorisées qu'en provenance des nœuds de reverse proxy (HAProxy/Nginx) vers l'écoute applicative de la machine **ECO-APP** sur le port technique 3000, ainsi que vers l'écoute centralisée du cluster PostgreSQL sur le port 5432.
- **Flux Zone Applicative à Zone DMZ :** Les serveurs internes sont autorisés à émettre des requêtes sortantes uniquement à destination du port 3128 du proxy Squid (DMZ). Ce canal unique valide et filtre le téléchargement des mises à jour système essentielles (apt).

- **Flux Zone Management à Toutes zones** : La cellule de supervision dispose de privilèges de lecture pour la collecte active des métriques et la centralisation des logs (ports Wazuh 1514/1515 et exportateurs Prometheus sur le port 9100). Aucun flux initié à l'inverse depuis une zone de production vers la zone Management n'est toléré.
- **Flux Zone IoT à Zone Applicative** : Les communications sont strictement limitées au seul script d'ingestion de données, qui dispose d'un accès unique vers le port 5432 du cluster PostgreSQL. Tout autre accès ou tentative de rebond vers le segment applicatif ou d'administration est bloqué.
- **Flux Tunnel OpenVPN à Zone Management** : Les connexions distantes validées par l'infrastructure PKI obtiennent une route chiffrée exclusive vers l'interface de gestion de l'hyperviseur Proxmox VE et vers les serveurs de la zone Management.

L'approche *Zero Trust* est rigoureusement matérialisée par l'application d'une règle implicite de fermeture globale (*Deny All*) sur toutes les interfaces du pare-feu pfSense : aucun flux n'est autorisé par défaut. Chaque exception fait l'objet d'une déclaration unitaire, documentée, justifiée et soumise à une journalisation systématique. En parallèle, l'IDS/IPS Suricata analyse en continu les paquets entrants sur l'interface WAN afin de corréler les signaux faibles et de transmettre les alertes de sécurité au SIEM Wazuh.

5. Solutions de protection déployées

Consigne : Pour chaque solution déployée, documentez la configuration, les tests effectués et les résultats obtenus. Les fichiers de configuration sont à joindre en Annexe.

5.1 Protection périmétrique et réseau

Configuration du firewall / NGFW : jeu de règles, politique par défaut, logging. IDS/IPS : signatures activées, règles custom créées, taux de faux positifs. VPN / solution d'accès distant — Références vers configurations en Annexe [X]

Pare-feu pfSense — Configuration et règles

L'Appliance de sécurité **pfSense** orchestre la politique de filtrage globale au carrefour des six ponts virtuels Proxmox (vmbr0 à vmbr5). La posture de sécurité adoptée est le *Default Deny* : la politique par défaut est configurée sur `block` (rejet silencieux) pour l'ensemble des interfaces, interdisant tout flux non explicitement déclaré.

Les règles de filtrage implémentées répondent aux exigences de cloisonnement strict de la plateforme Ecotrack :

- **Règle WAN → Zone DMZ** : Autorise le flux (`Pass`) sur le protocole TCP à destination exclusive de l'adresse IP virtuelle (VIP) Keepalived `10.10.1.100` sur les ports 80 (HTTP) et 443 (HTTPS). L'inspection de l'état des connexions est active (*established/related*) et la journalisation (*Log*) est systématiquement activée pour des fins d'audit.
- **Règle Zone DMZ → Zone Applicative (`LAN_APP`)** : Autorise le flux (`Pass`) sur le protocole TCP initié uniquement par les conteneurs de la DMZ (`ECO-DB` et `ECO-DB-02`) à destination de la machine `ECO-APP` sur le port 3000 (serveur web/API) et du cluster de données `ECO-DB` sur le port 5432 (PostgreSQL).
- **Règle Zone DMZ → Zone WAN (Flux sortants via Squid)** : Autorise le flux (`Pass`) sur le protocole TCP pour le sous-réseau de la DMZ (`10.10.1.0/24`) à destination de n'importe quelle adresse externe (*any*) sur les ports 80 et 443. Ce flux est intercepté par le proxy Squid pour contrôler, filtrer et auditer les requêtes sortantes (telles que les mises à jour système via *apt*).
- **Règle Zone Management (`LAN_MGT`) → Zones Applicative, DMZ et IoT** : Autorise le flux (`Pass`) sur les protocoles TCP/UDP initié depuis le sous-réseau d'administration `10.10.3.0/24` vers les autres zones. Ce privilège est strictement restreint aux ports de métrologie et de supervision (collecte des agents Wazuh et exportateurs Prometheus). Aucun flux inverse n'est autorisé.
- **Règle Zone IoT (`LAN_IOT`) → Zone Applicative (`LAN_APP`)** : Autorise le flux (`Pass`) sur le protocole TCP initié exclusivement par l'adresse IP du script d'ingestion automatisé à destination du port 5432 du nœud PostgreSQL principal (`ECO-DB`). Tout autre paquet en provenance de la zone IoT vers le reste du SI est rejeté.
- **Règle par défaut (Fermeture globale)** : `Block all` sur toutes les interfaces, avec journalisation active des paquets bloqués afin d'alimenter les règles de détection d'anomalies du SIEM.

Système de Détection et de Prévention d'Intrusions : IDS/IPS Suricata

La solution **Suricata** est déployée en mode IPS (*Inline Mode* via l'architecture Netmap) directement sur l'interface WAN de pfSense. Contrairement à un mode IDS passif, l'IPS est actif en coupure et détient le pouvoir d'intercepter et de rejeter instantanément les paquets malveillants avant qu'ils ne pénètrent l'infrastructure virtuelle.

La politique de détection s'appuie sur le chargement et le maintien à jour de plusieurs jeux de signatures spécifiques :

- **Emerging Threats (ET) Open Ruleset** : Détection du trafic réseau malveillant, des signatures de serveurs de Command & Control (C2), et des scanners de vulnérabilités opportunistes.
- **Règles anti-Déni de Service (DoS)** : Identification comportementale et par seuils des attaques par inondation de paquets (SYN Flood, HTTP Flood).
- **Règles de sécurité applicative** : Analyse approfondie des charges utiles (payloads) à la recherche de signatures d'injections SQL (SQLi) ou de failles Cross-Site Scripting (XSS) transitant au niveau réseau.

Afin d'éviter l'éviction de flux légitimes, le taux de faux positifs a fait l'objet d'un ajustement minutieux (*rule tuning*) lors des premières phases de tests de charge. L'ensemble des alertes et des événements de blocage générés par Suricata est transmis en temps réel via Syslog chiffré au serveur central Wazuh pour corrélation et historique.

Réseau Privé Virtuel : VPN OpenVPN — Accès Distants

Pour sanctuariser la surface d'exposition de l'infrastructure, le service **OpenVPN** est déployé directement sur le système hôte Debian (et non sur l'appliance pfSense), agissant comme une passerelle d'accès exclusive pour l'équipe. Ce choix permet de créer un rempart d'accès étanche avant d'atteindre l'interface d'administration de l'hyperviseur Proxmox VE et les segments internes.

La sécurité des accès repose sur des piliers d'authentification et de chiffrement robustes :

- **Gestion des identités (PKI)** : Une infrastructure à clés publiques locale, initialisée via **EasyRSA**, a permis de générer une autorité de certification (CA) interne et des certificats clients cryptographiques uniques, nominatifs et stricts pour chacun des cinq ingénieurs de l'équipe : *Abdallah, Boubacar, Wilfried, Terry et Salih*.
- **Obscurité et Obsidionale** : Le service écoute sur un port UDP personnalisé (non standard) pour s'affranchir des campagnes de scan automatisées qui ciblent le port par défaut 1194.
- **Double facteur de validation réseau** : L'authentification combine obligatoirement la vérification du certificat x509 du client et une clé de sécurité TLS statique partagée (`tls-auth`), bloquant à la racine les tentatives de scan de port et les attaques par déni de service contre la pile SSL/TLS d'OpenVPN.
- **Assignment réseau** : Dès la complétion du tunnel chiffré, les paquets des administrateurs sont injectés et confinés au sein du sous-réseau de la zone Management (`10.10.3.0/24`), leur ouvrant l'accès légitime aux outils de gouvernance.

Durcissement Système : OS Hardening du service SSH

Conformément aux directives de l'ANSSI, le démon SSH assurant l'administration à distance du serveur hôte Debian a fait l'objet d'un durcissement configurationnel drastique afin de neutraliser les vecteurs d'attaque par force brute et par usurpation d'identité :

- **Changement du port d'écoute** : Substitution du port standard 22 par un port personnalisé haut afin de réduire le bruit de fond des attaques automatisées sur Internet.
- **Désactivation des authentifications faibles** : Configuration de la directive `PasswordAuthentication no`, interdisant de manière absolue l'usage des mots de passe traditionnels, sensibles aux attaques par dictionnaire.
- **Authentification asymétrique obligatoire** : Activation exclusive de la directive `PubkeyAuthentication yes`, restreignant les connexions aux seules clés cryptographiques hautement sécurisées (recommandation des algorithmes de type Ed25519).
- **Interdiction d'accès direct au privilège suprême** : Implémentation de `PermitRootLogin no`. Aucun accès direct sous l'identité `root` n'est toléré sur le réseau. Les administrateurs doivent s'authentifier via leur compte utilisateur dédié avant de solliciter une élévation de privilèges traçable.

En complément, le service **Fail2ban** surveille en continu les journaux d'accès SSH. Il est configuré avec une politique de tolérance zéro : si une adresse IP source génère plus de 3 tentatives d'authentification infructueuses sur une fenêtre glissante de 10 minutes, elle est instantanément bannie au niveau du pare-feu pour une durée ferme de 24 heures.

5.2 Sécurisation des applications web (OWASP)

La sécurisation des applications web requiert une approche systématique fondée sur le référentiel OWASP Top 10, complétée par le déploiement d'un pare-feu applicatif web (WAF) et par des tests de pénétration cibles.

Pour chaque vulnérabilité OWASP Top 10 : mesure de mitigation implémentée, configuration du WAF ModSecurity (règles OWASP Coré Rule Set actives, ajustements réalisés), tests de validation effectués — Captures et logs en Annexe [X]

Sécurisation du Top 10 OWASP via Nginx et ModSecurity

La zone DMZ intègre un pare-feu applicatif (WAF) basé sur le serveur web **Nginx** et le module **ModSecurity**. Ce dispositif s'appuie sur le jeu de règles standardisées **OWASP Core Rule Set (CRS)**, configuré de manière stricte afin d'intercepter et de neutraliser les attaques ciblant la couche applicative.

Le flux d'ingestion et de traitement des requêtes HTTP/HTTPS respecte la cinématique réseau suivante :

Internet → HAProxy (Écoute ports 80/443) → Nginx + ModSecurity (Port interne 81) → Conteneur ECO-APP (Port applicatif 3000).

L'intégration de cette architecture multicouche permet de traiter systématiquement chacune des catégories de vulnérabilités du **Top 10 OWASP** :

A01 — Broken Access Control (Contrôle d'accès défaillant)

- **Mesures de protection** : L'accès aux ressources est cloisonné dès la couche réseau par les règles de filtrage du pare-feu **pfSense**, interdisant toute communication directe de l'extérieur vers la zone applicative. Au niveau de la persistance, le modèle **RBAC** de PostgreSQL applique une ségrégation stricte des privilèges (rôles distincts pour l'application, la lecture seule ou l'écriture). Enfin, la validation et l'intégrité des sessions utilisateurs sont garanties au niveau du code de l'application par la vérification systématique de jetons **JWT** (JSON Web Tokens) signés.

A02 — Cryptographic Failures (Chaudronnerie et failles cryptographiques)

- **Mesures de protection** : Les connexions externes et internes de l'infrastructure Ecotrack imposent l'usage exclusif du protocole **TLS**. Au repos, les colonnes contenant des informations critiques au sein de la base de données PostgreSQL fait l'objet d'un chiffrement fort. Les jetons de session active sont stockés de manière éphémère dans le cache **Redis** avec l'application d'une durée de vie restrictive (*Time-To-Live*). Côté applicatif, le stockage des secrets s'appuie sur l'algorithme de hachage robuste **bcrypt**.

A03 — Injection (SQL, NoSQL et commandes système)

- **Mesures de protection** : ModSecurity applique les règles de détection des injections SQL et de commandes du CRS, configurées au niveau de paranoia 2 (*Paranoia Level 2*) pour bloquer les tentatives de contournement. En profondeur, les vulnérabilités d'injection sont neutralisées au sein du code par l'implémentation systématique de requêtes préparées et paramétrées, complétées par un mécanisme rigoureux de validation et d'assainissement (*sanitization*) des entrées côté serveur.
- **Validation par test d'intrusion** : L'injection d'une charge utile de type Cross-Site Scripting ou injection de script telle que `<script>alert(1)</script>` est instantanément interceptée par le WAF ModSecurity, coupant la connexion et retournant un code d'erreur standardisé HTTP 403 Forbidden.

A04 — Insecure Design (Conception non sécurisée)

- **Mesures de protection :** La sécurité a été intégrée dès la phase de conception (*Security by Design*) à travers la segmentation étanche de l'infrastructure en cinq zones distinctes, interdisant structurellement à une base de données d'être exposée ou interrogée directement depuis l'Internet public. Chaque compte de service, conteneur ou machine virtuelle est instancié selon le principe du moindre privilège requis pour son fonctionnement nominal.

A05 — *Security Misconfiguration (Mauvaise configuration de sécurité)*

- **Mesures de protection :** Chaque système d'exploitation et composant logiciel subit une procédure de durcissement rigoureuse (*Hardening*) : désactivation des services et modules inutilisés, fermeture des ports non essentiels et automatisation des correctifs de sécurité. En parallèle, les agents **Wazuh FIM** (*File Integrity Monitoring*) surveillent en continu les fichiers de configuration système et applicatifs majeurs, déclenchant une alerte immédiate en cas de modification non autorisée.

A06 — *Vulnerable and Outdated Components (Composants vulnérables et obsolètes)*

- **Mesures de protection :** Afin de maîtriser la chaîne d'approvisionnement logicielle, aucune machine virtuelle interne ne dispose d'un accès direct à Internet pour télécharger des dépendances. Les flux sortants sont canalisés et audités par le forward proxy **Squid** (mises à jour via `apt-get` sous contrôle). Un inventaire centralisé des versions logicielles est maintenu par le SIEM **Wazuh**, qui corrèle ces données avec les flux de vulnérabilités publiques (CVE) pour signaler instantanément l'apparition d'une faille sur un composant.

A07 — *Identification and Authentication Failures (Failles d'identification et d'authentification)*

- **Mesures de protection :** La surface d'authentification est protégée contre les attaques par force brute et par dictionnaire à l'aide de **Fail2ban**, qui applique un bannissement IP automatique après 3 échecs consécutifs. Les sessions applicatives gérées par la base en mémoire Redis intègrent un mécanisme d'expiration stricte, tandis que l'accès global à l'infrastructure d'administration requiert la validation d'un certificat cryptographique **OpenVPN** individuel et révoquant à distance.

A08 — *Software and Data Integrity Failures (Manque d'intégrité des logiciels et des données)*

- **Mesures de protection :** L'intégrité des paquets logiciels installés sur la distribution Debian 12 est vérifiée par le contrôle systématique des

signatures cryptographiques GPG via le relais du proxy Squid. Au niveau du système de fichiers, le module FIM de **Wazuh** supervise l'empreinte des binaires critiques et des bibliothèques partagées afin de détecter toute altération ou injection de code malveillant au repos.

A09 — Security Logging and Monitoring Failures (Carence de journalisation et de surveillance)

- **Mesures de protection** : Cette catégorie est couverte de manière exhaustive par le déploiement de notre SOC centralisé. Le serveur **Wazuh SIEM** collecte et centralise l'ensemble des journaux d'événements du parc. Ces données sont indexées et historisées au sein d'un cluster **Elasticsearch**, puis restituées visuellement à travers des tableaux de bord d'observabilité opérationnelle sur **Grafana**. Un moteur de corrélation active génère des alertes de sécurité en temps réel lors de la détection de comportements déviants.

A10 — Server-Side Request Forgery (SSRF)

- **Mesures de protection** : Les tentatives d'exploitation de failles SSRF — visant à détourner le serveur applicatif pour lui faire requêter des ressources internes ou externes à son insu — sont contrées en amont par les règles spécifiques SSRF activées au sein du jeu de règles OWASP CRS de ModSecurity. En aval, le pare-feu pfSense applique des règles de filtrage de sortie strictes, bloquant toute requête réseau anormale ou non initiée par un comportement nominal en provenance de la DMZ.

5.3 Chiffrement et infrastructure à clé publique (PKI)

Stratégie de chiffrement : protocoles et algorithmes retenus pour chaque usage (transport TLS 1.3, données au repos AES-256, authentification crypte/Argon2, signatures RSA/ECDSA). PKI si déployée : hiérarchie des autorités, cycle de vie des certificats, politique de révocation (CRL/OCSP)

Stratégie de chiffrement

La stratégie de chiffrement de l'infrastructure **Ecotrack** couvre trois usages distincts et indispensables : la sécurisation des flux en transit, la protection des données stockées au repos et la robustesse des mécanismes d'authentification.

Transport TLS 1.3 (Chiffrement en transit)

Toutes les communications externes et inter-zones exposées (flux utilisateurs → HAProxy → Nginx) imposent l'usage exclusif du protocole **TLS 1.3**. Les versions antérieures (TLS 1.0, 1.1 et 1.2) sont explicitement désactivées afin de prémunir l'architecture contre les attaques par rétrogradation (*downgrade attacks*).

Dans le cadre de ce laboratoire technique, les certificats d'infrastructure sont auto-signés et générés via la suite d'outils **OpenSSL**. Lors d'un passage en production industrielle, ces derniers seraient remplacés par des certificats signés par une autorité publique reconnue via des mécanismes d'automatisation (tels que le protocole ACME de Let's Encrypt).

Données au repos et durcissement (Chiffrement au repos)

La protection des données persistantes est orchestrée au niveau de la couche applicative et de la base de données :

- **Chiffrement applicatif ciblé** : Les colonnes hautement sensibles de la base de données **PostgreSQL 15** (contenant les identifiants, les jetons d'accès et les secrets applicatifs de la plateforme Ecotrack) sont chiffrées de manière granulaire. Cette opération s'appuie sur l'extension native **pgcrypto** configurée avec l'algorithme de chiffrement symétrique **AES-256-CBC**.
- **Protection des secrets d'infrastructure** : Les fichiers de configuration système contenant des secrets ou des identifiants d'administration en clair (tels que `patroni.yml`, `redis.conf` ou les configurations de pfSense) sont sanctuarisés au niveau du système de fichiers Debian. Ils font l'objet de permissions UNIX strictes (attribution exclusive via un `chmod 600` restreignant l'accès en lecture/écriture au seul propriétaire légitime, sous l'identité de l'utilisateur `root` ou du service dédié).

Authentification et gestion des jetons

La robustesse de l'accès aux services s'appuie sur des mécanismes de hachage et de signature modernes :

- **Hachage des secrets d'accès** : Les mots de passe des utilisateurs stockés au sein du cluster PostgreSQL ne sont jamais inscrits en clair. Ils font l'objet d'un hachage salé via l'algorithme robuste **bcrypt**, configuré avec un facteur de travail élevé (*work factor* de 12), ce qui immunise les secrets contre les attaques par dictionnaire et le cassage de clés hors-ligne (*offline brute-force*).
- **Jetons de session** : L'état des sessions actives au sein du cache en mémoire Redis est matérialisé par des jetons **JWT** (JSON Web Tokens). L'intégrité et la non-falsification de ces jetons sont garanties par l'application d'une signature cryptographique basée sur le mécanisme **HMAC-SHA256**.

Signatures RSA / ECDSA

Le déploiement des services d'infrastructure applique un arbitrage précis entre performance de calcul et robustesse cryptographique :

- **Autorités de certification** : Les clés de l'autorité de certification (CA) s'appuient sur des clés asymétriques **RSA de 4096 bits**, garantissant une longévité et une résistance maximales à la base de la chaîne de confiance.
- **Certificats clients et serveurs** : Les connexions d'infrastructure et les accès OpenVPN exploitent des clés basées sur les courbes elliptiques via l'algorithme **ECDSA P-256**. Ce choix offre un excellent compromis de sécurité tout en minimisant la charge processeur et la latence lors de la phase de poignée de main (*handshake*) sur les équipements de virtualisation.

Infrastructure à clé publique (PKI)

Une infrastructure à clés publiques (PKI) interne dédiée a été déployée et initialisée via l'outil **EasyRSA** afin d'administrer l'intégralité du cycle de vie des certificats cryptographiques associés aux liaisons OpenVPN.

La hiérarchie de confiance est structurée selon l'architecture descendante suivante :

- **Autorité de Certification Racine** : Cette racine s'appuie sur une clé RSA de 4096 bits disposant d'une période de validité de 10 ans. Elle sert exclusivement à signer et à valider les entités de niveau inférieur, et sa clé privée est confinée.
- **Certificats Serveurs** : Le certificat d'identité de la passerelle VPN est signé directement par la CA racine et configuré avec une période de validité opérationnelle de 2 ans.
- **Certificats Clients** : La CA racine signe de manière unitaire les certificats d'accès individuels attribués à chacun des cinq ingénieurs de l'équipe (*Abdallah, Boubacar, Wilfried, Terry et Salih*). Par mesure de sécurité et pour limiter la portée d'une éventuelle compromission, ces certificats clients disposent d'une validité restreinte à 1 an.

La révocation des accès en cas de compromission d'une clé ou de départ d'un opérateur est administrée manuellement par le biais d'une liste de révocation de certificats (**CRL - Certificate Revocation List**). Ce fichier d'index est mis à jour sur la passerelle OpenVPN à chaque révocation pour interdire instantanément toute nouvelle tentative d'établissement de tunnel par l'identité déchue. Dans le cadre d'un déploiement en production d'entreprise, ce mécanisme manuel serait remplacé par un répondeur **OCSP (Online Certificate Status Protocol)** permettant la vérification du statut des certificats en temps réel et sans latence.

6. Scripts d'automatisation sécurité

Consigne : Présentez les scripts Python ou Bash développés pour automatiser des tâches de sécurité. Joignez le code commenté en Annexe et argumentez leur intérêt opérationnel.

Pour chaque script (2 à 3 minimum) : objectif, description fonctionnelle, technologies / bibliothèques utilisées, exemple d'exécution et de sortie, cas d'usage opérationnel — Reference vers code source en Annexe [X]

Script 1 — Simulateur des scripts IoT (MQTT Publisher)

Objectif : simuler des capteurs environnementaux en générant des données aléatoires et en les publiant sur le broker Mosquito.

<https://github.com/sidiama/ECOTRACKINGETIS.git>

Script 2 — Ingestion MQTT vers PostgreSQL (MQTT Subscriber)

Objectif : surveiller en continu le broker Mosquito et insérer chaque nouvelle mesure reçue dans la base de données PostgreSQL en temps réel.

<https://github.com/sidiama/ECOTRACKINGETIS.git>

Script 3 — Audit de sécurité SSH et rapport (Security Audit Script)

L'objectif de cette solution est de vérifier automatiquement, sans intervention manuelle, que la politique de sécurité de l'ANSSI est bien appliquée sur l'ensemble de l'infrastructure.

1. Le Fonctionnement

Depuis la machine de sécurité, un script interroge périodiquement chaque machine virtuelle via le **port SSH personnalisé**. Il exécute une série de commandes locales pour tester la configuration réelle de chaque système.

2. Les Points de Contrôle Clés

Pour chaque machine virtuelle, le script valide les critères essentiels de votre durcissement :

- **Interdiction d'accès direct à Root :** Sécurisation contre l'usage du compte administrateur suprême sur le réseau.
- **Désactivation des mots de passe :** Obligation d'utiliser des clés cryptographiques asymétriques, insensibles aux attaques par dictionnaire.

- **Contrôle de Fail2ban :** Vérification que le service est actif et correctement configuré pour bloquer définitivement une IP après un maximum de 3 tentatives infructueuses.

3. L'Utilité Métier

- **Détection des dérives :** Si un membre de l'équipe modifie temporairement une configuration (par exemple, pour un test) et oublie de la reverrouiller, le script le détecte immédiatement.
- **Génération de preuves d'audit :** Le rapport Markdown généré sert de livrable de conformité (idéal dans le cadre d'une démarche de certification type ISO 27001).

7. Conclusion et bilan

Bilan de la mission : posture de sécurité atteinte vs initiale, limites de l'architecture proposée, vecteurs d'attaque résiduels, perspectives d'amélioration et pistes pour une certification ISO 27001

Posture de sécurité atteinte

À l'issue de ce projet, l'infrastructure Ecotrack présente une posture de sécurité significativement renforcée par rapport à un déploiement standard ou par défaut. L'intégration combinée des différentes briques technologiques a permis de matérialiser les acquis fondamentaux suivants :

- **Segmentation réseau stricte :** Compartimentation de l'infrastructure en cinq zones de confiance hermétiques, isolées au niveau de la couche de liaison par les ponts virtuels de l'hyperviseur Proxmox VE et gouvernées par la politique restrictive du pare-feu **pfSense**.
- **Haute disponibilité de la couche DMZ :** Élimination de tout point unique de défaillance (*SPOF - Single Point of Failure*) grâce à la mise en œuvre du protocole VRRP via **Keepalived**, couplé à la répartition de charge dynamique de **HAProxy**.
- **Protection applicative active :** Immunisation des points d'entrée web vis-à-vis des attaques complexes grâce au pare-feu applicatif (WAF) **ModSecurity** adossé au jeu de règles standardisées **OWASP CRS**.
- **SOC opérationnel et centralisé :** Visibilité complète et surveillance continue de l'état du système d'information par la centralisation, l'indexation et la corrélation des journaux d'événements via la suite **Wazuh SIEM**, **Elasticsearch** et **Grafana**.

- **Gouvernance des accès distants** : Déploiement d'une infrastructure à clés publiques (PKI) dédiée, verrouillant les privilèges d'administration derrière des tunnels chiffrés **OpenVPN** nominatifs.
- **Pipeline IoT durci** : Sécurisation de l'ingestion des flux de terrain (température, poids, batterie, quantité) par le biais d'un broker **Mosquitto** authentifié et isolé.

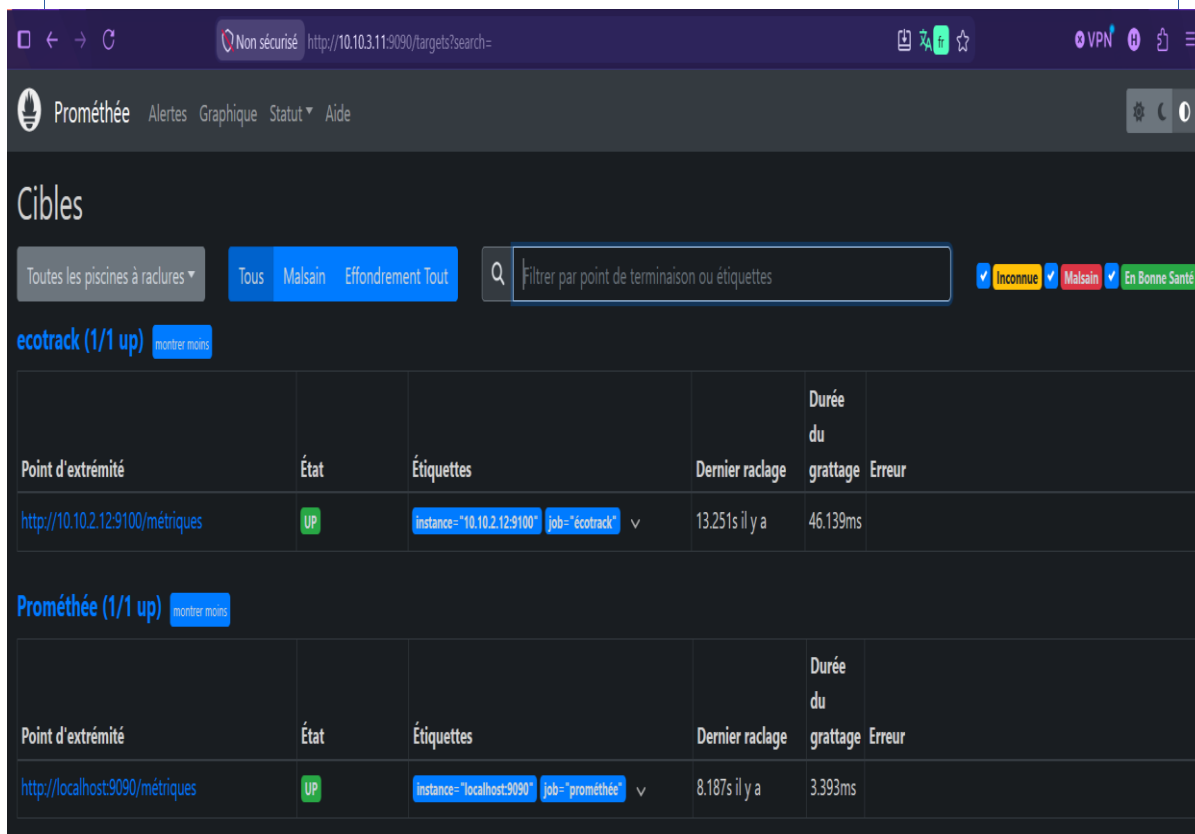


Figure 4

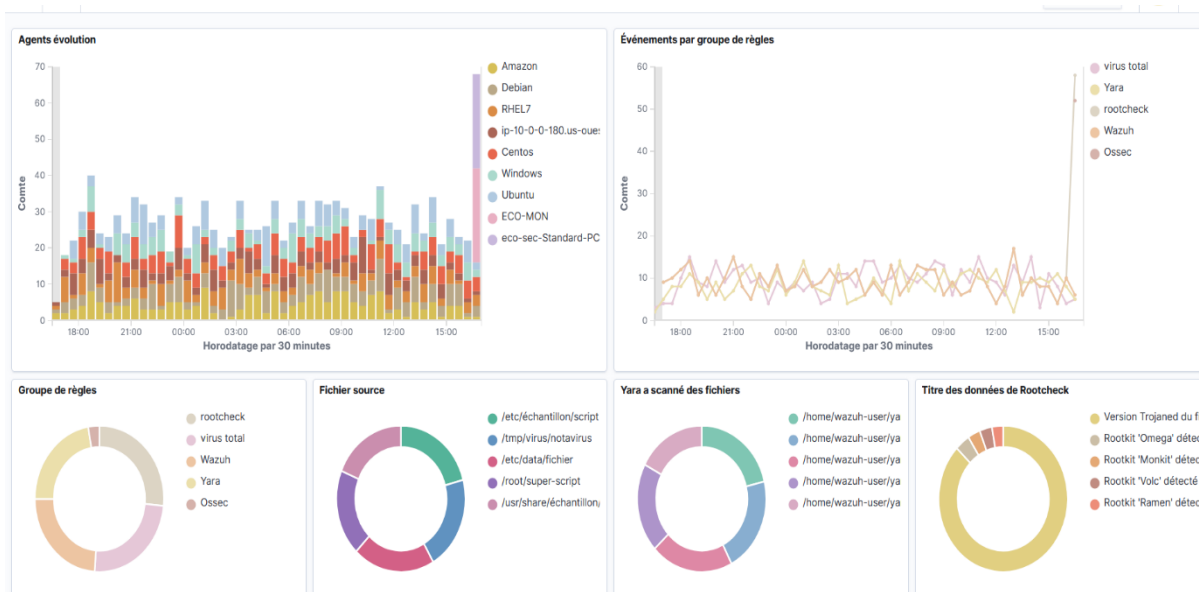


Figure 5

Limites de l'architecture proposée

Bien que l'architecture réponde rigoureusement aux critères de la défense en profondeur, certaines limites inhérentes au contexte de déploiement subsistent :

- **Contexte de laboratoire et certificats** : L'intégralité des certificats d'infrastructure et des liaisons TLS repose sur des clés auto-signées générées localement. Un passage en production industrielle imposerait l'usage d'une PKI d'entreprise reconnue ou l'automatisation d'une autorité publique telle que Let's Encrypt.
- **Absence de chiffrement de bout en bout du trafic interne** : Si les flux externes sont chiffrés, les communications inter-VM transitant au sein du réseau virtuel Proxmox entre la DMZ et la zone applicative s'effectuent en clair. Cette configuration repose sur l'hypothèse de confiance accordée à l'étanchéité des ponts logiques de l'hyperviseur.
- **Carence de stratégie de sauvegarde automatisée** : La résilience des données face aux sinistres ou aux ransomwares reste partielle. Aucune politique de backup automatisée, planifiée et externalisée n'a été implémentée pour le cluster PostgreSQL, limitant la récupération à des extractions manuelles via `pg_dump`.
- **Surveillance IoT périphérique restreinte** : L'authentification auprès du broker MQTT Mosquitto s'appuie exclusivement sur des identifiants statiques. La sécurité de ce segment mériterait d'être renforcée par l'implémentation d'une authentification par certificats TLS mutuels (mTLS) côté capteurs.

Vecteurs d'attaque résiduels

L'analyse de risques met en évidence plusieurs vecteurs de compromission résiduels contre lesquels l'architecture actuelle ne peut lutter que partiellement :

- **Compromission ou vol d'un accès OpenVPN** : En cas de compromission de la clé privée ou de la station de travail de l'un des cinq membres de l'équipe, un attaquant obtiendrait une route directe vers la zone Management. La mise en place d'une authentification multifacteur (MFA) constitue la parade indispensable à envisager.
- **Vulnérabilité de type 0-day sur les composants de tête** : L'apparition d'une faille de sécurité non publique affectant directement pfSense ou le noyau de Proxmox VE échappe au périmètre des contre-mesures passives. Ce risque impose le maintien d'une cellule de veille active sur les vulnérabilités et l'application immédiate des correctifs (CVE).
- **Attaque interne ou élévation par utilisateur privilégié** : Le principe du *Zero Trust* n'est pas encore totalement appliqué au niveau de la couche d'administration de l'hyperviseur. Les opérateurs partagent des privilèges

étendus sur la console Proxmox, ce qui expose l'infrastructure à des risques d'erreurs de manipulation ou de sabotage interne.

Perspectives d'évolution vers la certification ISO/IEC 27001

Pour faire évoluer l'infrastructure Ecotrack vers un niveau de maturité industrielle conforme aux exigences de la norme internationale **ISO/IEC 27001:2022**, un plan de transformation structuré selon les axes suivants doit être initié :

- **Axe Gouvernance** : Formalisation et rédaction d'une Politique de Sécurité du Système d'Information (**PSSI**) documentée, définissant les rôles, les responsabilités et les chartes d'utilisation des ressources informatiques.
- **Axe Gestion des Vulnérabilités** : Implémentation d'un processus de balayage de vulnérabilités et de conformité automatisé, corrélé de manière continue avec les bases de données CVE pour réduire la fenêtre d'exposition des VM.
- **Axe Continuité d'Activité** : Industrialisation d'une solution de sauvegarde chiffrée, compartimentée et testée de manière régulière. Cette démarche implique la définition formelle des objectifs de temps de récupération (**RTO**) et de perte de données maximale admissible (**RPO**).
- **Axe Contrôle des Accès** : Durcissement des accès aux interfaces d'administration (Proxmox, pfSense, commutateurs virtuels) par l'ajout obligatoire d'un second facteur d'authentification (**MFA** de type TOTP ou clé matérielle FIDO2) s'ajoutant aux certificats de la PKI OpenVPN.
- **Axe Audit et Validation** : Planification d'un audit de sécurité technique et d'un test de pénétration (*Pentest*) mené par une équipe de sécurité externe indépendante (**Red Team**) afin de valider l'étanchéité de l'architecture défensive face à des scénarios de cyberattaques avancées.

Grâce à sa conception modulaire et documentée, le projet Ecotrack constitue une base technique et organisationnelle saine pour engager l'organisation dans une telle démarche de certification.

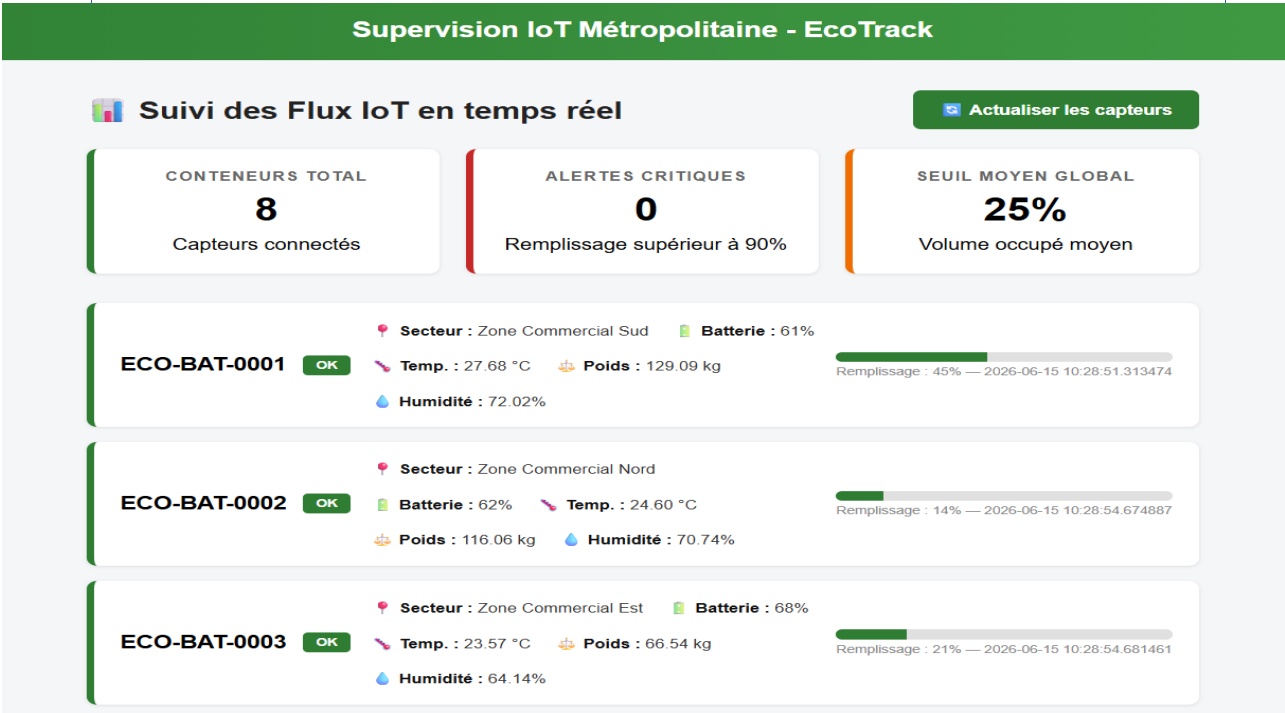


Figure 6

BIBLIOGRAPHIE ET SOURCES

1. Références Académiques et Normalisation (Gouvernance & Risques)

- **ANSSI (Agence nationale de la sécurité des systèmes d'information).** (2021). *Guide d'hygiène informatique : Renforcer la sécurité de son système d'information en 42 mesures*. Version 2.0. Paris : ANSSI.
- **ANSSI.** (2022). *Mise en œuvre du principe de défense en profondeur dans les architectures réseau*. Note technique. Paris : ANSSI.
- **ISO/IEC 27001:2022.** *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Genève : Organisation internationale de normalisation.
- **ISO/IEC 27005:2022.** *Information security, cybersecurity and privacy protection — Guidance on managing information security risks*. Genève : Organisation internationale de normalisation.
- **Microsoft Corporation.** (2009). *The STRIDE Threat Modeling Approach*. Microsoft Security Engineering Team. Réf. technique MS-STRIDE.

2. Documentations Techniques Officielles (Infrastructure & Durcissement)

- **Debian Project.** (2025). *Debian Securing Manual: Securing the OpenSSH Daemon*. Repéré à : <https://www.debian.org/doc/manuals/securing-debian-manual/>
- **Fail2ban Documentation.** (2024). *Fail2ban Configuration Guide: Mitigating SSH Brute-Force Attacks with Jail.local*. Repéré à : <https://www.fail2ban.org/wiki/index.php/MANUAL>
- **HAProxy Technologies.** (2025). *HAProxy Configuration Manual: Layer 7 Load Balancing, Stick-Tables and Rate-Limiting*. Repéré à : <https://cbonte.github.io/haproxy-dconv/>
- **OWASP Foundation.** (2021). *OWASP Top 10:2021 — The Core Trust Deficiencies in Web Applications*. Repéré à : <https://owasp.org/www-project-top-ten/>
- **OWASP CRS Team.** (2023). *OWASP ModSecurity Core Rule Set (CRS) v3.3.X Architecture & Paranoia Levels*. Repéré à : <https://coreruleset.org/docs/>
- **Patroni Authors.** (2024). *Patroni: PostgreSQL High Availability with etcd Consensus Clusters*. Open-source documentation. Repéré à : <https://patroni.readthedocs.io/>
- **pfSense Project.** (2025). *pfSense Software Documentation: Multi-VLAN Segmentation, State Tables and Default Deny Filtering*. Austin : Rubicon Communications (Netgate).
- **Proxmox Server Solutions.** (2025). *Proxmox VE Virtualization Environment Administration Guide: Network Bridges (vbr) and Logical Segmentation*. Vienne : Proxmox GmbH.
- **Suricata Engine.** (2024). *Suricata User Guide: Inline IPS Mode Configuration via Netmap*. Open Information Security Foundation (OISF).

- **Wazuh Inc.** (2025). *Wazuh Solution Architecture: File Integrity Monitoring (FIM) and Syslog Log Collection*. Repéré à : <https://documentation.wazuh.com/>

3. Sources de Veille Technologique (Anglais Technique)

- **CISA (Cybersecurity and Infrastructure Security Agency)**. *Known Exploited Vulnerabilities Catalog & Cyber Alerts*. Édité par le Département de la Sécurité intérieure des États-Unis. Source de veille quotidienne pour la remédiation des CVE.
- **CVE Program (MITRE Corporation)**. *Common Vulnerabilities and Exposures Official Database*. Base de corrélation exploitée par notre SIEM Wazuh pour la détection des failles sur nos composants (Debian, Nginx, PostgreSQL).
- **NVD (National Vulnerability Database)**. *NIST CVSS v3.1 Calculator and Vulnerability Metrics*. Calculateur utilisé pour l'évaluation de la sévérité intrinsèque des 6 menaces STRIDE.
- **The Hacker News**. *Cybersecurity News & Analysis for IT Professionals*. Flux de veille technologique anglophone utilisé pour anticiper les attaques sur les architectures Web/DMZ.

4. Références Numérique Responsable

- **ADEME / INR (Institut Numérique Responsable)**. (2023). *Guide de l'éco-conception des services numériques : Bonnes pratiques d'optimisation des architectures virtuelles*. Paris : ADEME.
- **Hetzner Online GmbH**. (2025). *Environmental Sustainability and Energy Efficiency in Bare Metal Datacenters*. Gunzenhausen : Hetzner. (Utilisé pour valider l'impact environnemental et l'éco-responsabilité de l'hébergeur physique sélectionné).

Contribution Personnelle et Réalisation de l'Infrastructure

Bien que ce projet ait été une aventure collective menée en synergie au sein de notre groupe de cinq ingénieurs, je profite de cette conclusion personnelle pour poser un regard réflexif sur les compétences et les enseignements que cette expérience m'a apportés.

Un apprentissage forgé par la pratique

Au démarrage du projet, nous avons été confrontés à des défis techniques majeurs qui ont mis nos certitudes à l'épreuve : la mise en place d'une segmentation réseau étanche, le déploiement de notre environnement de virtualisation et la configuration fine de nos premiers outils de sécurité ont exigé une phase d'expérimentation intense, jalonnée d'essais, d'erreurs et de réajustements logiques.

Avec le recul, je mesure précisément le chemin parcouru. Si je devais réitérer ce projet aujourd'hui, je l'aborderais avec une assurance et une efficacité démultipliée : les verrous techniques d'hier, qu'il s'agisse de la maîtrise fine des permissions ou de la levée de blocages sur les terminaux, sont aujourd'hui devenus des automatismes.

L'audace technologique : de la simulation à la production

L'un des tournants majeurs de ce projet a été la transition d'un environnement de simulation local — où nous maîtrisions des outils comme VMware — vers le déploiement en production d'un hyperviseur Proxmox VE hébergé sur un serveur dédié en ligne via l'offre Hetzner. C'était une première pour notre équipe.

Nous avons délibérément choisi de sortir de notre zone de confort en optant pour Proxmox VE plutôt que de nous reposer sur des solutions d'émulation traditionnelles. Ce choix architectural s'est révélé extrêmement formateur : il nous a confrontés aux réalités concrètes des infrastructures de production et à la rigueur indispensable pour administrer un serveur exposé.

Vers une expertise durable en cybersécurité

Je suis pleinement conscient que notre architecture finale pour la plateforme n'est pas immuable et qu'elle présente encore de nombreux axes d'optimisation. C'est précisément cette perfectibilité qui fait la valeur de ce projet à mes yeux : il a agi comme un puissant catalyseur.

Plus qu'un simple livrable académique, la réalisation de l'infrastructure a été le déclencheur d'une ambition professionnelle durable. Elle m'a donné le goût de l'architecture défensive et m'incite aujourd'hui à approfondir, de manière autonome, des briques de sécurité avancées telles que le déploiement de SIEM, l'intégration d'IDS/IPS et le durcissement d'infrastructure (*hardening*).